AIOT 期末專題 • Proposal



AI SOC Analyst Agent

結合 MITRE ATT&CK 領域知識與 LLM 推理的資安告警分級代理人

第 16 組 • 蘇恩平、周妤、袁靖淇、蕭宥瑄 • 2026 年 11 月

01 • 動機

攻擊越來越多，偵測越來越慢

263 萬次

中共對我國關鍵基礎設施的每日網路侵擾（2025 年，較 2024 年增加 6%）

國安局 2025 報告 [23]

14 天

攻擊者在環境中的潛伏時間中位數；網路間諜與北韓 IT 人員案件長達 122 天

Mandiant M-Trends 2026 [15]

444 萬美元

資料外洩的全球平均成本；從發生到偵測、圍堵平均 241 天

IBM Cost of a Data Breach 2025 [14]

偵測與回應的速度決定損失大小：大量使用 AI 與自動化的組織，平均省下 190 萬美元、縮短 80 天 [14]

數字皆取自 2025–2026 年官方報告

02 • 背景

SOC 如何處理告警

資安產品產生告警 → SIEM / XDR 彙整 → **Tier-1 分級（本專題）** → Tier-2/3 調查與處置

TP 真陽性

真實的惡意活動

例：帳號遭盜用後橫向移動 → 圍堵、調查

BP 良性陽性

偵測正確，但活動是授權或無害的

例：資安團隊的滲透測試 → 建立例外

FP 誤報

偵測邏輯本身有誤

例：把正常備份誤判為資料外傳 → 修正規則

TP / BP / FP 為 GUIDE 資料集的分級標籤 [1]；實務上多數「誤報」其實是 BP [24]

03 • 問題

分級是瓶頸，現有方法各有缺口

ML 分級 [1][7]

缺少脈絡

可大規模部署，但較少說明告警在攻擊鏈中的意義

LLM Agent [3][4]

≥ 40.4%

五種推理策略都漏判至少這麼多攻擊告警；調查 benchmark 最佳僅 0.606

人機協作 [12]

自動化自滿

696 名分析師調查：自動化提高後會降低監控、更依賴自動化結果

研究問題

能否結合 ML、資安領域知識與 LLM 推理，給出有依據、可解釋，並且知道何時該交給人的事件分級？

告警疲勞是 SOC 的結構性問題 [8][9]

Article Summary（節錄 7 / 16 篇）

AI 技術 8 篇　領域知識 8 篇

文獻	方法	資料	主要發現	限制
[1] Freitas 2024	ML 分級（CGR）	GUIDE，100 萬起事件	已部署至數千個客戶	未比較其他模型；不處理 zero-day
[3] Tsegai 2026	5 種 LLM Agent + AIDA	ALERT-BENCH，1,247 告警	漏判 ≥ 40.4%；AIDA 降至 3.1%	僅 AIT 單一資料系列
[4] Wu 2026	LLM Agent + SQL 工具	Azure 環境，57 張 log 表	最佳 reward 僅 0.606	單一受控環境
[6] Lekssays 2025	RAG 對應 ATT&CK	多個威脅情資 benchmark	少量標註即達 SOTA	只處理情資文字
[10] Sadlek 2025	Kill Chain 攻擊圖	測試平台攻擊情境	告警序列分類 AUC 0.95	非 LLM、限測試平台
[12] Tilbury 2026	PLS 結構方程模型	696 份問卷 + 29 場訪談	自動化導致分析師自滿	僅美國分析師
[25] Kersten 2025	Think-aloud 實地研究	商業 SOC，Tier-1 共 400 次調查	需升級的告警要更多樣的資訊	僅一家 SOC

完整 16 篇的 8 欄 Article Summary Table 見 Proposal 文件 §3.3

05 • Research Gap

從既有研究到本專題

Existing Research

ML 分級 [1][7]

LLM Agent [2][3][4]

ATT&CK / Kill Chain [6][10][11]

SOC 實務與人因 [12][24]–[26]

Limitations

缺少攻擊鏈脈絡

證據不足就結案

知識未整合、無升級設計

輸出不易驗證

Research Gap

缺少同時整合 ML、ATT&CK 知識與 LLM，並以明確的升級機制處理不確定性與證據不足、可重現評估的 SOC Agent

Our Project

GBDT 分級 + SHAP

ATT&CK RAG + 攻擊鏈規則

證據融合 + 人工複核

GUIDE + ExCyTIn 評估

綜述 [8] 亦指出：營運驗證、跨環境泛化、評估方法是領域主要缺口

06 • Deep Research Q1

五個核心思維模式 → 系統設計

思維模式	關鍵證據	對應設計
M1 Assume Breach：查無紀錄 ≠ 沒有攻擊	潛伏中位數 14 天 [15]；Agent 查無紀錄時最易誤判結案 [3]	擴大查詢；用完預算仍不確定就升級
M2 看攻擊鏈脈絡，不看單一告警	Kill Chain 分級 AUC 0.95 [10]；GUIDE 標籤在事件層級 [1]	以事件為單位；攻擊鏈階段作為特徵與規則
M3 錯誤成本不對稱	外洩平均 444 萬美元 [14]；降低漏判需付出升級代價 [3]	漏判率為首要指標，同時報告升級率
M4 看攻擊行為（TTPs），不看 IOCs	Pyramid of Pain [20]；入侵途徑持續變化 [15]	以 ATT&CK 技術為知識單位；避免依賴 IP、hash
M5 自動化要可驗證	自動化造成自滿，系統性驗證可減緩 [12]；可驗證才會被採用 [26]	每個結論附證據鏈；衝突時明確標示

每一項的意義、證據與設計影響詳見 Proposal 文件 §4 Q1

07 • Deep Research Q2

三個專業爭論

全自動 AI SOC ↔ 人機協作

A：AI 與自動化可縮短 80 天處理週期 [14]

B：LLM 漏判 ≥ 40.4% [3]；自動化造成自滿 [12]

共識：AI 處理低風險事件，高風險交給人 [2][3]

未解：升級門檻怎麼校準？責任歸誰？

立場：人機協作，ML 負責效率

規則式偵測 ↔ 機器學習

A：規則透明可稽核；ML 用於入侵偵測有根本困難 [19]

B：ML 分級已在數千個組織部署 [1][7]

共識：混合式，規則管已知，ML 管排序與降誤報 [8]

未解：對抗穩健性 [8]、概念漂移

立場：GBDT + Kill Chain 規則約束

公開資料集能否代表真實 SOC

A：GUIDE 為真實事件、真實分析師標籤 [1]

B：CICIDS2017 超過 20% 流量需重新標註 [17]；評估陷阱普遍 [16]

共識：多資料集驗證、避免資料洩漏 [16]

未解：缺少真實且完整標註的端到端 benchmark

立場：GUIDE + ExCyTIn，依事件與組織切分

結構：觀點 A ↔ 觀點 B → 證據 → 共識 → 未解問題 → 本專題立場（Proposal 文件 §4 Q2）

08 • Deep Research Q3

十個深度理解問題（舉 4 例）

Trade-off

全部升級給人，漏判率就是 0，為什麼不是好答案？

重點：人力有限，過度升級造成告警疲勞，反而漏看

What-if

攻擊者知道 Agent「查無紀錄就結案」，他會怎麼做？

重點：刪除或停用 log；資料缺失本身就是升級訊號

Design Decision

為什麼分級主力是 GBDT，而不是直接讓 LLM 判斷？

重點：GUIDE 欄位匿名化、成本與校準、LLM 漏判率高

Evidence

把 GUIDE 隨機切成 train / test，會出什麼問題？

重點：同事件、同組織資料洩漏；應依事件、組織或時間切分

另含 Why、Failure Case、Comparison、Real-world Scenario 等 6 題（Proposal 文件 §4 Q3）

09 • Proposed Solution

Agent 給分析師的六項能力

事件分級
判斷 TP / BP / FP，附信心分數

說明依據
SHAP 特徵、相似歷史事件、資料來源

ATT&CK 對應
攻擊技術與攻擊鏈推進階段

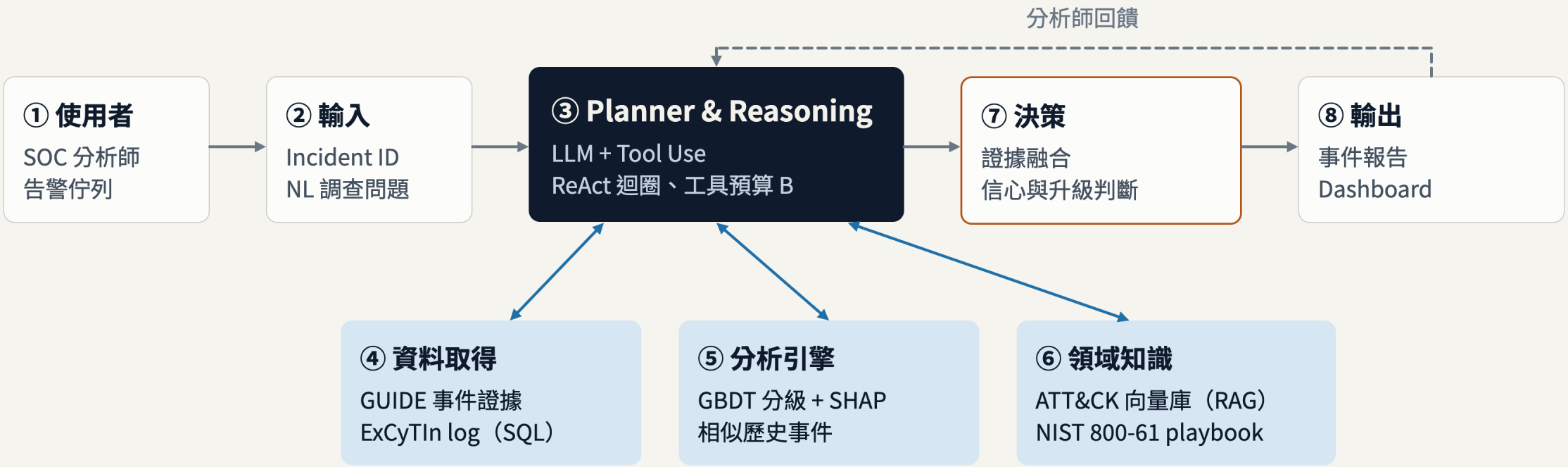
處置建議
依 NIST SP 800-61 Rev. 3 建議動作

主動升級
不確定、有衝突、高風險或證據不足時交給人

自然語言調查
自己查 log 回答，並附上紀錄來源

刻意不做：自動執行處置、即時防禦、偵測攻擊本身

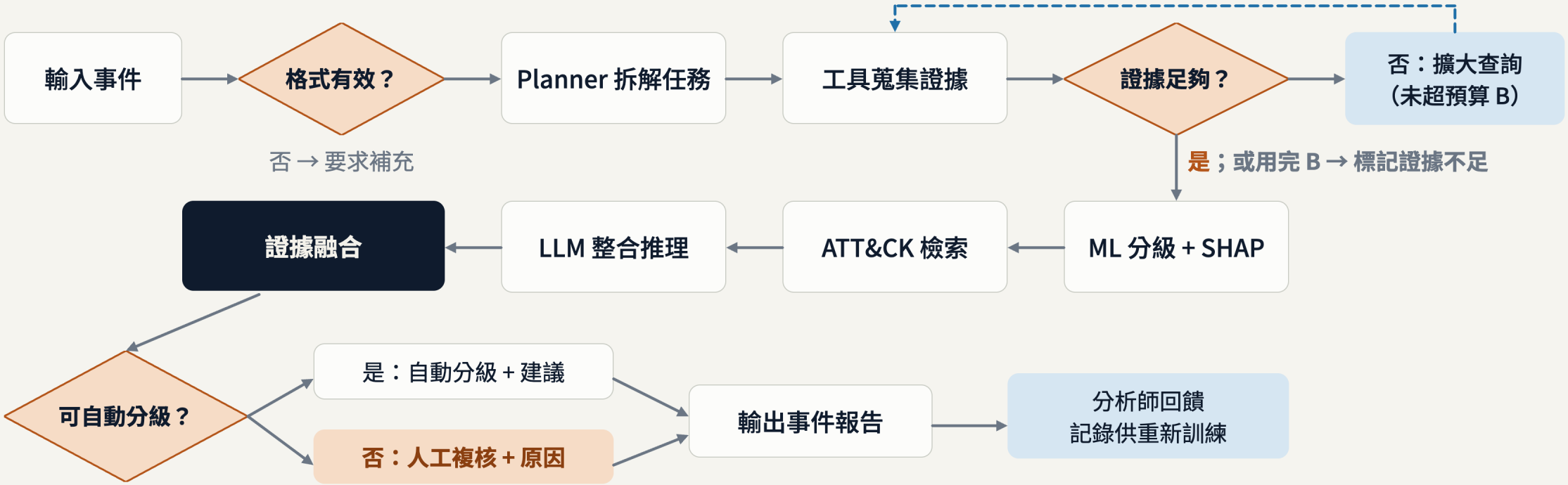
八個模組，以 Planner 為中心



藍色雙向箭頭：Planner 透過工具呼叫 ④⑤⑥；虛線：分析師修正回饋

11 • Flowchart

一個事件的處理流程



菱形：Decision；藍色虛線：Loop（Assume Breach）；可自動分級 = 信心 ≥ τ、無衝突、非高風險、證據足夠

Algorithm 1：SOC Triage Agent

```
01 req ← ValidateAndParse(Q)
02 if req invalid then return Error
03 plan ← Planner.Decompose(req)
04 E ← ∅ ; calls ← 0
05 repeat
06   tool ← Planner.SelectTool(plan, E)
07   E ← E ∪ tool.Execute(req, E)
08   calls ← calls + 1
09 until IsSufficient(E) or calls ≥ B
10 x ← ExtractFeatures(E)
11 p ← M.PredictProba(x)
12 φ ← SHAP(M, x)
```

```
13 S ← SimilarIncidents(x, k)
14 T ← MapToATTACK(E, KB)
15 K ← KB.Retrieve(T) ∪ PB.Retrieve(T)
16 llm ← LLM.Reason(E, p, φ, S, T, K)
17 (label, conf, flags) ← Fuse(p, llm, T)
18 if conf < τ or conflict or high_risk
     or not IsSufficient(E)
19   R.status ← NEEDS_HUMAN_REVIEW
20 else
21   R.status ← AUTO_TRIAGED
22 R.actions ← PB.Recommend(label, T)
23 R ← R ∪ {label, conf, E, φ, S, T, flags}
24 return R
```

01–02 ② 輸入驗證 | 05–09 ③④ 證據迴圈（M1） | 10–13 ⑤ 分析 | 14–16 ⑥③ 知識與推理 | 17–24 ⑦⑧ 決策與輸出

IsSufficient：每筆告警有證據、主要實體有上下文、空查詢須確認 log 未中斷

13 • Pseudocode

Algorithm 2：Evidence Fusion

```
01 flags ← ∅
02 q ← OneHot(llm.label, llm.confidence)
03 s ← w_ml · p + w_llm · q
04 label ← argmax(s) ; conf ← max(s)
05 if argmax(p) ≠ llm.label then
06   flags ← flags ∪ {conflict}
07 if Rules(T) has high-risk pattern then
08   flags ← flags ∪ {high_risk}
09   if label ≠ TP and p_TP ≥ τ_safety
10     then label ← TP
11 return (label, conf, flags)
```

02–04 • 加權融合

LLM 只回報低／中／高信心（0.5／0.7／0.9），與 ML 機率加權平均

05–06 • 衝突偵測

ML 與 LLM 結論不同就標記，交由人工複核

07–10 • 安全優先（M3）

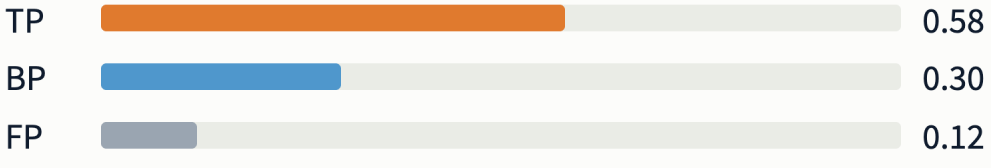
攻擊鏈到後段時，TP 機率過安全門檻就改判 TP

w_ml、w_llm、τ、τ_safety 只在驗證集上調整，不用測試集調參 [16]

分析師會看到的事件報告

事件 #12345 分級報告

需人工複核



Initial Access　Credential Access • T1110　**Lateral Movement • T1021**

依據：Tactic 覆蓋數、Detector 誤報率低；3 個相似事件中 2 個為 TP

建議：重設帳號密碼、檢查橫向移動目標主機、保留證據

升級原因：攻擊鏈到 Lateral Movement；證據不足（查無該帳號登入紀錄）

分級 + 信心
ML 與 LLM 融合後的三類機率

攻擊鏈
對應 ATT&CK 技術與推進階段

證據鏈
SHAP、相似事件與處置建議

升級原因
說明為什麼要人來看

設計示意：事件、數字與帳號皆為虛構，非實驗結果

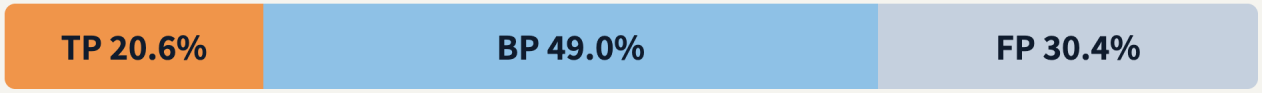
GUIDE：已下載並實際檢查

70.7 萬
起有標籤事件

5,769
個組織

432
種 ATT&CK 技術

事件層級標籤分布（訓練集）



TP 是少數類別：以 class weight 處理，並以 TP 漏判率為首要指標

可讀文字（LLM 讀得懂）

Category、MitreTechniques、EntityType、SuspicionLevel、LastVerdict

匿名化數字 ID

AlertTitle、IP、帳號、裝置、檔名、URL

→ 分級以 ML 為主，LLM 負責 ATT&CK 推理與報告

GUIDE_Train.csv（2.4 GB、951.7 萬列）實際檢查；另以 ExCyTIn-Bench 評估 log 調查能力 [4]

五個實驗與消融分析

實驗	比較對象（Baselines）	指標
E1 分級準確度	多數類別、Detector 誤報率規則、純 GBDT、純 LLM	Macro-F1、TP 漏判率、人工升級率
E2 ATT&CK 對應	純 LLM vs. LLM + RAG	Technique / Tactic 的 Precision、Recall
E3 調查推理	ExCyTIn 論文公布分數、單輪 LLM	Benchmark reward
E4 報告品質	無 RAG 的報告（抽樣事件）	正確性、證據完整性、可執行性評分
E5 成本	—	每事件 token 數、延遲、工具呼叫次數
Ablation	分別移除 ⑤ 分析、⑥ 知識、升級規則	同 E1

主要結果以「漏判率–升級率」取捨曲線呈現；資料依事件與組織切分，避免資料洩漏

E1、E2、E4、Ablation 用 GUIDE；E3 用 ExCyTIn-Bench；E5 兩者皆量測；LLM 實驗以分層抽樣控制成本

技術選型與開發時程

模組	技術
資料處理	Python、pandas、DuckDB
分級模型	LightGBM / XGBoost、SHAP
領域知識	ATT&CK STIX、Chroma 向量庫
Agent	LLM API（tool use），不自行訓練 LLM
介面	Streamlit

- ✓ GUIDE 已下載，欄位與標籤已實際檢查
- ✓ 分級模型只需 CPU，筆電即可訓練

開發時程（約 6 週，自 Proposal 後起算）

1. 資料探索、確認欄位 W1
2. 特徵工程、GBDT 與 baseline W1–W2
3. ATT&CK 知識庫與 RAG W2–W3
4. Agent 主流程與報告 W3–W4
5. ExCyTIn 整合與完整實驗 W5
6. Dashboard、文件、期末簡報與影片 W6

主要風險：LLM 成本 → 工具與 token 預算、抽樣評估；ExCyTIn 建置困難 → 以 Splunk BOTS v3 替代

預期成果與貢獻

可驗證的假設（尚未實驗）

1. 整合知識與升級機制後，TP 漏判率低於純 GBDT 與純 LLM
2. 漏判率與升級率的取捨可被量化，作為設定門檻的依據
3. ATT&CK 知識檢索提升技術對應正確性與報告可解釋性

預期貢獻

系統：整合 ML、ATT&CK 與 LLM 的 SOC 分級 Agent

方法：把領域原則轉成證據融合與升級演算法

實驗：兩個公開資料集上可重現的比較與消融

交接：README、DESIGN.md 與完整程式碼

Proposal 階段不提供實驗數據；實際結果將於期末報告呈現

References

[1] Freitas et al. Copilot Guided Response & GUIDE. arXiv 2024
[2] Wei et al. CORTEX. arXiv 2025
[3] Tsegai et al. Reliable SOC Agents (AIDA). arXiv 2026
[4] Wu et al. ExCyTIn-Bench. ICML 2026
[5] Deason et al. CyberSOCEval. arXiv 2025
[6] Lekssays et al. TechniqueRAG. ACL Findings 2025
[7] Freitas et al. Adaptive Incident Prioritization. arXiv 2026
[8] Ndichu et al. AI Alert Screening Survey. arXiv 2026
[9] Habibzadeh et al. LLMs for SOCs Survey. arXiv 2025
[10] Sadlek et al. Kill Chain Attack Graph Triage. JISA 2025
[11] Garcia et al. ROSCA. WATCH 2025
[12] Tilbury, Flowerday. The Vigilance Paradox. ICS 2026
[13] NIST SP 800-61 Rev. 3. 2025
[14] IBM. Cost of a Data Breach Report 2025
[15] Mandiant. M-Trends 2026
[16] Arp et al. ML Pitfalls in Security. USENIX Sec 2022
[17] Engelen et al. Troubleshooting CICIDS2017. SPW 2021
[18] Tilbury, Flowerday. Automation Preferences. MWAIS 2025
[19] Sommer, Paxson. Outside the Closed World. S&P 2010
[20] Bianco. The Pyramid of Pain. 2013
[21] Rose et al. NIST SP 800-207 Zero Trust. 2020
[22] Strom et al. MITRE ATT&CK Design and Philosophy. 2018
[23] 國家安全局。2025 年中共對我國關鍵基礎設施網駭威脅分析。2026
[24] Alahmadi et al. 99% False Positives. USENIX Sec 2022
[25] Kersten et al. Tier-1 Alert Investigation. USEC 2025
[26] Banstola et al. Agentic AI Companion in a SOC. arXiv 2026

完整書目（IEEE 格式、DOI 與連結）見 Proposal 文件 §6